containment and control requirements is designed to help ensure all information covered by the requirements of the GLBA[55] are appropriately safeguarded and that sufficient information is assessed to fulfill the more narrowly tailored obligation to notify affected individuals. For example, assessment of any incident involving unauthorized access to or use of customer information will help facilitate the evaluation of whether sensitive customer information has been accessed or used without authorization, which informs whether notice has to be provided. Additionally, a covered institution's assessment may also be useful for collecting other information that is required to populate the notice, such as identifying the date or estimated date of the incident, among other details. Therefore, the scope of the incident response program is appropriate, and we are adopting as proposed.

1. Assessment

The final amendments will require that the incident response program include procedures for: (1) assessing the nature and scope of any incident involving unauthorized access to or use of customer information, and (2) identifying the customer information systems and types of customer information that may have been accessed or used without authorization.[56] We did not receive comments addressing the assessment portion of the incident response program and are adopting it as proposed.[57]

---

55 The GLBA directs the Commission to establish standards to insure the security and confidentiality of customer records and information; to protect against any anticipated threats or hazards to the security or integrity of such records; and to protect against unauthorized access to or use of records or information which could result in substantial harm or inconvenience to any customer. 15 U.S.C. 6801(b).

56 *See* final rule 248.30(a)(3)(i). The proposed requirements related to assessing the nature and scope of a security incident are consistent with the components of a response program as set forth in the Banking Agencies' Incident Response Guidance. *See* Banking Agencies' Incident Response Guidance.

57 Although no comments discussed only the assessment requirement, multiple comments discussed the incident response program generally, which includes the assessment requirement. These comments are discussed in section II.A.

The assessment requirement is designed to require a covered institution to identify both the customer information systems and types of customer information that may have been accessed or used without authorization during the incident, as well as the specific customers affected, which would be necessary to fulfill the obligation to notify affected individuals.[58] Information developed during the assessment process may also help covered institutions develop a contextual understanding of the circumstances surrounding an incident, as well as enhance their technical understanding of the incident, which should be helpful in guiding incident response activities such as containment and control measures. The assessment process may also be helpful for identifying and evaluating existing vulnerabilities that could benefit from remediation in order to prevent such vulnerabilities from being exploited in the future. Further, covered institutions generally should consider reviewing and updating the assessment procedures periodically to ensure that the procedures remain reasonably designed.[59]

2. Containment and Control

The final amendments will require that the response program have procedures for taking appropriate steps to contain and control a security incident, in order to prevent further unauthorized access to or use of customer information.[60] We did not receive comments discussing the containment and control portion of the incident response program and are adopting as proposed.[61]

---

58 For example, a covered institution's assessment may include gathering information about the type of access, the extent to which systems or other assets have been affected, the level of privilege attained by any unauthorized persons, the operational or informational impact of the breach, and whether any data has been lost or exfiltrated.

59 *See also* 17 CFR 270.38a-1, 275.206(4)-7.

60 *See* final rule 248.30(a)(3)(ii). These proposed requirements are consistent with the components of a response program as set forth in the Banking Agencies' Incident Response Guidance. *See* Banking Agencies' Incident Response Guidance at 15752.

61 Although no comments discussed only the containment and control requirements, multiple comments

As set forth in the proposal, the objective of containment and control is to prevent additional damage from unauthorized activity and to reduce the immediate impact of an incident by removing the source of the unauthorized activity.[62] Strategies for containing and controlling an incident vary depending upon the type of incident and may include, for example, isolating compromised systems or enhancing the monitoring of intruder activities, searching for additional compromised systems, changing system administrator passwords, rotating private keys, and changing or disabling default user accounts and passwords, among other interventions. Because incident response may involve making complex judgment calls, such as deciding when to shut down or disconnect a system, developing and implementing written containment and control policies and procedures will provide a framework to help facilitate improved decision making at covered institutions during potentially high-pressure incident response situations. Further, covered institutions generally should consider reviewing and updating the containment and control procedures periodically to ensure that the procedures remain reasonably designed.[63]

3. Notice to Affected Individuals

As part of their incident response programs, covered institutions will be required under the final amendments to provide a clear and conspicuous notice to affected individuals under certain circumstances.[64] We are adopting this requirement substantially as proposed, with some changes in response to comments.

---

discussed the incident response program generally, which includes the containment and control requirement. These comments are discussed in section II.A.

[62] *See* Proposing Release at Section II.A.2. For a further discussion of the purposes and practices of such containment measures, *see generally* CISA Incident Response Playbook, at 14; *see also* Federal Financial Institutions Examination Council ("FFIEC"), Information Technology Examination Handbook – Information Security (Sept. 2016), at 52, *available at* https://ithandbook.ffiec.gov/media/274793/ffiec_itbooklet_informationsecurity.pdf.

[63] *See also* 17 CFR 270.38a-1, 275.206(4)-7.

[64] *See* final rule 248.30(a)(4).

We are adopting as proposed, a requirement for a covered institution to notify each affected individual whose sensitive customer information was, or was reasonably likely to have been, accessed or used without authorization, unless the covered institution has determined, after a reasonable investigation of the incident, that sensitive customer information has not been, and is not reasonably likely to be, used in a manner that would result in substantial harm or inconvenience. The covered institution will be required to provide a clear and conspicuous notice to each affected individual by a means designed to ensure that the individual can reasonably be expected to receive actual notice in writing. Also as proposed, the final amendments require the notice to be provided as soon as practicable, but not later than 30 days, after the covered institution becomes aware that unauthorized access to or use of customer information has occurred or is reasonably likely to have occurred. Lastly, in a modification from the proposal, the final amendments provide for an incrementally longer period of time than the proposal for a covered institution to delay providing notice to affected individuals in cases where the Attorney General has determined that providing the notice would pose a substantial risk to national security or public safety. These requirements are discussed in detail below.

a. Standard for Providing Notice and Identification of Affected Individuals

We are adopting as proposed a requirement for a covered institution to provide notice to individuals whose sensitive customer information was, or is reasonably likely to have been, accessed or used without authorization, unless, after a reasonable investigation of the facts and circumstances of the incident of unauthorized access to or use of sensitive customer information, it determines that sensitive customer information has not been, and is not reasonably likely to be,

used in a manner that would result in substantial harm or inconvenience.[65] The final amendments reflect a presumption of notification: a covered institution must provide a notice unless it determines notification is not required following a reasonable investigation. Also as proposed, if an incident of unauthorized access to or use of customer information has occurred or is reasonably likely to have occurred, but a covered institution is unable to identify which specific individuals' sensitive customer information has been accessed or used without authorization, the final amendments require the covered institution to provide notice to all individuals whose sensitive customer information resides in the customer information system that was, or was reasonably likely to have been, accessed without authorization ("affected individuals").[66]

While the incident response program is generally required to address information security incidents involving any form of customer information,[67] notification is only required when there has been unauthorized access to or use of sensitive customer information, a subset of customer information, because it presents increased risks to affected individuals.[68] This notice standard is designed to give affected individuals an opportunity to mitigate the risk of substantial harm or inconvenience arising from an information security incident that potentially implicates their sensitive customer information by affording them an opportunity to take timely responsive

---

65 Final rule 248.30(a)(4)(i).

66 Final rule 248.30(a)(4)(ii). This proposed provision was not intended to require notification of customers whose sensitive customer information resided in the affected customer information system if the covered institution has reasonably determined that such customers' sensitive customer information was not accessed or used without authorization. Accordingly, we have modified the final rule to reflect this intended result. *See infra* footnote 102 and accompanying text.

67 *See infra* section II.B.1.

68 *See infra* section II.A.3.b. Additionally, customer information that is not disposed of properly could trigger the requirement to notify affected individuals under final rule 248.30(a)(4)(i). For example, a covered institution whose employee leaves un-shredded customer files containing sensitive customer information in a dumpster accessible to the public would be required to notify affected customers, unless the institution has determined that sensitive customer information has not been, and is not reasonably likely to be, used in a manner that would result in substantial harm or inconvenience.

actions, such as monitoring credit reports for unauthorized activity, placing fraud alerts on relevant accounts, or changing passwords used to access accounts. At the same time, the final amendments provide a mechanism for covered institutions to avoid making unnecessary notifications in cases where, following a reasonable investigation, the institution determines that sensitive customer information has not been, and is not reasonably likely to be, used in a manner that would result in substantial harm or inconvenience to the affected individual.[69]

Whether an investigation is reasonable will depend on the particular facts and circumstances of the unauthorized access or use. For example, unauthorized access or use that is the result of intentional intrusion by a threat actor may warrant more extensive investigation than inadvertent unauthorized access or use by an employee. The investigation may occur in parallel with an initial assessment and scoping of the incident and may build upon information generated from those activities. The scope of the investigation generally should be refined by using available data and the results of ongoing incident response activities. Information related to the nature and scope of the incident may be relevant to determining the extent of the investigation, such as whether the incident is the result of internal unauthorized access or use of sensitive customer information or an external intrusion, the duration of the incident, what accounts have been compromised and at what privilege level, and whether and what type of customer information may have been copied, transferred, or retrieved without authorization.[70]

A covered institution cannot avoid its notification obligations in cases where an investigation's results are inconclusive. Instead, the notification requirement is excused only where a reasonable investigation supports a determination that sensitive customer information

---

69 *See infra* section II.A.3.c.

70 For example, depending on the nature of the incident, it may be necessary to consider how a malicious intruder might use the underlying information based on current trends in identity theft.

has not been and is not reasonably likely to be used in a manner that would result in substantial harm or inconvenience. Thus, in a case where a threat actor has gained access to a customer information system that stores sensitive customer information, and the covered institution lacks information indicating that any particular individual's sensitive customer information stored in that customer information system was or was not used in a manner that would result in substantial harm or inconvenience, a covered institution will be required to provide notice to affected individuals even though it may not have a sufficient basis to determine whether the breach would result in substantial harm or inconvenience.[71] Pursuant to the amendments, as proposed and adopted, for any determination that a covered institution makes that notice is not required, covered institutions other than funding portals will be required to maintain a record of the investigation and basis for its determination.[72]

As further described below,[73] a number of commenters supported the proposal's requirement for covered institutions to provide notices promptly, emphasizing the importance of ensuring that customers receive timely notification when their sensitive customer information is reasonably likely to have been subject to unauthorized access or use so they have an opportunity to effectively respond to the incident.[74] One commenter stated that timeliness is key because any delay will impact consumers' ability to take steps to protect themselves from identify theft, account compromise, and other downstream impacts resulting from the initial harm of the unauthorized access or use.[75] According to this commenter, a breach notification regime is

---

71 *See* final rule 248.30(a)(4)(ii).

72 *See infra* section II.C; *see also infra* footnote 385.

73 *See infra* section II.A.3.d.

74 *See*, *e.g.*, Better Markets Comment Letter; EPIC Comment Letter; NASAA Comment Letter; ICI Comment Letter 1; Nasdaq Comment Letter.

75 *See* EPIC Comment Letter; *see also* Better Markets Comment Letter (customers whose information has

fundamentally deficient if it does not empower consumers with the information and tools necessary to take action to protect themselves or understand what risks they may face as a result of a breach.[76]

Several commenters proposed alternative notification standards, some expanding the circumstances requiring customer notification, and others suggesting a narrower notification regime.[77] One commenter suggested we require notification for any incident of unauthorized access to or use of sensitive information, regardless of the risk of harm or inconvenience.[78] According to this commenter, customers should always be notified when their sensitive information is accessed or used without authorization, which would allow customers to determine for themselves whether they believe there is a risk of substantial harm or inconvenience that should prompt action on their part. Similarly, another commenter suggested that the notification standard should be expanded from a "reasonably likelihood" standard to a "reasonably possible" standard with regard to whether an individual's sensitive customer information was accessed or used without authorization.[79] This commenter stated that this change was necessary to protect against the possibility that a covered institution might conclude it lacked sufficient information to find the reasonably likely standard satisfied if, for example, it knows it has been hacked but is unable to determine the scope of the hack. According to these commenters, the seemingly higher threshold proposed by the Commission, coupled with their

---

been exposed need appropriate and timely notifications to decide for themselves whether and how to address the breach to avoid being "victimized twice": first when the breach occurs, and then again when "bad actors use the information to steal their identity, drain their bank accounts, or run up their credit cards").

76 *See* EPIC Comment Letter.

77 *See*, *e.g.*, Better Markets Comment Letter, NASAA Comment Letter (proposing more expansive standards); SIFMA Comment Letter 2, CAI Comment Letter, IAA Comment Letter 1 (proposing narrower standards).

78 *See* Better Markets Comment Letter.

79 *See* NASAA Comment Letter.

belief that businesses want to avoid making disclosures that could incur liability or lose customers, leaves open the potential that customers will not be notified of some information security compromises that could threaten their investments.[80] One commenter suggested that, in addition to requiring notifications to affected individuals, the rules should be modified to also require that covered institutions provide notice to the Commission whenever they are providing notice to affected individuals.[81]

By contrast, with regard to narrowing the standard, some commenters suggested eliminating the presumption of notification altogether, such that covered institutions would have a notification obligation only after having affirmatively determined, following an investigation, a likelihood of a breach or resulting harm to customers.[82] These commenters suggested that eliminating the notification presumption, and allowing for the completion of an investigation, would provide covered institutions with additional time to respond to and mitigate an incident as opposed to spending time deliberating over notification obligations, and would allow for more informed notifications. These commenters also suggested that this approach would be more consistent with certain state law regimes that only require notification where an investigation shows a risk of harm and the Banking Agencies' Incident Response Guidance.[83] To address the

---

80 *See* Better Markets Comment Letter; NASAA Comment Letter; *see also* EPIC Comment Letter ("EPIC agrees that businesses have a natural tendency to want to avoid making disclosures that could incur liability or lose customers").

81 *See* Better Markets Comment Letter.

82 *See*, *e.g.*, SIFMA Comment Letter 2 (notification should only be required if the covered institution makes an affirmative finding of substantial harm or inconvenience); CAI Comment Letter (proposing revised notification trigger to no later than 30 days from a determination that actual or reasonably likely unauthorized access to sensitive customer information has occurred); ACLI Comment Letter (suggesting trigger should instead be only after the completion of a reasonable investigation and conclusion of the incident response process).

83 The Banking Agencies' Incident Response Guidance advises that a covered institution should provide notice to affected customers if, following the conclusion of a reasonable investigation, it has determined that misuse of sensitive customer information has occurred or is reasonably possible. *See* Banking

concern that lengthy investigations might unduly delay customer notifications, one commenter suggested revising the rule to separately require covered institutions "to conduct a prompt investigation of potential incidents," which the commenter stated would better align with certain existing state law standards while still providing a mechanism for timely notifications.[84]

We considered the alternative approaches suggested by commenters but determined that adopting the standard as proposed strikes an appropriate balance in accommodating the relevant competing concerns. The suggestions to expand the circumstances requiring notification (either by requiring notification regardless of the risk of harm, or by expanding notification to include cases where it is "reasonably possible" that an individual's sensitive customer information was accessed or used without authorization) raise over-notification concerns, particularly given that the adopted standard already has a presumption towards notification.[85] We also disagree that the "reasonably likely" standard would allow a covered institution that knows it suffered a breach to avoid providing notice simply by pointing to a lack of information about the scope of the breach as the commenter recommending this approach suggested.[86] To the contrary, under the proposed and final amendments, if it is reasonably likely that a malicious actor gained access to a covered institution's information system containing sensitive customer information but the scope of the breach is unclear (i.e., the covered institution is unable to determine which specific individuals' sensitive customer information has been accessed or used without authorization and cannot make the determinations required under the rule to avoid sending notices), the covered institution

---

Agencies' Incident Response Guidance. *See also* section II.A.3.d(1) (responding to commenters' concerns that the proposed notification timing requirements provide an insufficient amount of time for covered institutions to conduct a reasonable investigation of a data breach incident and prepare and send notices to affected individuals).

84 *See* CAI Comment Letter.

85 *See supra* footnotes 78-80 and accompanying text.

86 *See* NASAA Comment Letter.